MINISTRY OF EDUCATION
IMAM ABDULRAHMAN BIN
FAISAL UNIVERSITY
COLLEGE OF COMPUTER SCIENCE
& INFORMATION TECHNOLOGY

وزارة التعليم
جامعة الإمام
عبدالرحمن بن فيصل
كلية علوم الحاسب
وتقنية المعلومات

جامعة الإمام عبدالرحمن بن فيصل
IMAM ABDULRAHMAN BIN FAISAL UNIVERSITY

Cybersecurity Policy for a Small Organization

CYS 401 – Fundamentals of Cybersecurity

Academic Year (2025-2026) – First Semester

Group 5

ID Number	Member Name
2230003701	Renad Abulghani Mengash
2230005632	Lamyaa Saleh Alyami
2230003566	Hind Abdullah Alghumiz
2230003342	Ghuzail Muhammad Alhajri

Table of Contents

Introduction....4

Organization Background....4

Core Security Policies....5

1. Password Policy....5

1.1 Purpose and Scope....5

1.2 Core Principles....5

1.3 Detailed Policy Directives....5

1.4 Compliance and Enforcement....6

2. Access Control Policy....6

2.1 Purpose and Scope....6

2.2 Core Principles....6

2.3 Detailed Policy Directives....6

2.4 Compliance and Enforcement....7

3. Acceptable Use Policy....7

3.1 Purpose and Scope....7

3.2 Fundamental Principles....7

3.3 Policy Directives....7

3.4 Compliance and Enforcement....8

4. Device Security Policy....8

4.1 Purpose and Scope....8

4.2 Central Concepts....8

4.3 Detailed Policy Directives....9

4.4 Compliance and Enforcement....9

5. Data Protection and Privacy Policy....10

5.1 Purpose and Scope....10

5.2 Core Principles....10

5.3 Detailed Policy Directives....11

5.4 Compliance and Enforcement....12

6. Incident Response Policy 13
6.1 Purpose and Scope 13
6.2 Core Principles 13
6.3 Detailed Policy Directives 14
6.4 Compliance and Enforcement 15
7. Email and Communication Policy 15
7.1 Purpose and Scope 15
7.2 Core Principles 16
7.3 Detailed Policy Directives 16
7.4 Compliance and Enforcement 17
8. Physical Security Policy 17
8.1 Purpose and Scope 17
8.2 Core Principles 17
8.3 Detailed Policy Directives 17
8.4 Compliance and Enforcement 18
9. Training and Awareness Policy 18
9.1 Purpose and Scope 18
9.2 Core Principles 18
9.3 Detailed Policy Directives 19
9.4 Compliance and Enforcement 19
Justification & Importance 20
Compliance & Enforcement 21
Conclusion 22
References 23

Introduction

Cybersecurity has become one of the most essential requirements for any modern organization, regardless of its size or industry. With the continuous rise of cyber threats, data breaches, phishing attacks, and unauthorized access, small organizations are often more vulnerable because they typically lack strong security controls and formal protection procedures[1]. Therefore, establishing a clear and structured cybersecurity policy is critical to ensure the confidentiality, integrity, and availability of organizational data[1].

This cybersecurity policy aims to provide a foundational framework that guides the organization in protecting its digital assets, managing user access, securing devices, and responding to security incidents. The policy is designed to help employees understand their responsibilities, follow best practices, and maintain a secure working environment[1][4]. By applying these guidelines, the organization can significantly reduce the risk of cyberattacks and improve overall security awareness among staff members.

Organization Background

The chosen organization for this project is a small training center that provides educational workshops and short courses for students and professionals. The center operates with approximately 15 employees, including administrative staff, trainers, IT support, and customer service personnel. Most daily operations depend on digital systems such as computers, email communication, online registration platforms, and cloud-based data storage.

The training center handles various types of information, including student personal data, payment details, registration forms, training materials, and internal documents. Because this information is sensitive and valuable, the organization must follow strict security measures to prevent data leakage, unauthorized access, and cyber incidents that could disrupt operations or harm students' privacy[2].

The center uses basic IT infrastructure such as office computers, Wi-Fi networks, an internal management system, and email accounts for communication. However, like many small organizations, it does not have a dedicated cybersecurity team, which makes having a clear and well-structured cybersecurity policy even more important to ensure safe and secure operations[1][3].

Core Security Policies

These are the operational policies that form the base of the cybersecurity framework in a training center, therefore setting forth certain strict regulations that have to be followed regarding the use of technical assets, access control, and protection standards within the work environment. In fact, the development of such controls is an essential condition for the information security management systems according to [1].

1. Password Policy

1.1 Purpose and Scope

The password is considered the first line of defense against unauthorized access. This policy is concerned with setting important standards that contribute to generating and managing strong passwords that no one can easily guess and to ensuring the confidentiality of the Center's data and reducing security incidents for employees. This policy is primarily applied to everyone who uses any resource of the Center, such as employees and contractors [1].

1.2 Core Principles

The policy consists of three basic principles that contribute to maintaining account integrity. First: Strength and Complexity, as passwords must be complex enough to withstand automated hacking attempts and brute-force attacks. Second: Confidentiality. Passwords are considered highly personal, so it is strictly forbidden to share them with anyone (even a relative) or to disclose them by writing them clearly, as security becomes compromised once they are revealed. Third: Regular change of passwords to prevent the account from being hacked, in addition to not allowing the reuse of old or compromised passwords [5].

1.3 Detailed Policy Directives

This policy imposes rules for managing passwords, including setting the minimum password length, which must be at least 12 characters, and ensuring the inclusion of uppercase and lowercase letters, numbers, and symbols, as recommended by security standards [6]. Employees are also required to renew them at least once every 90 days, with the prohibition of using any of the previous passwords. To protect the system, it must be designed so that the account is locked in case of five failed login attempts. Unlocking requires communication with the Information Technology (IT) department. Furthermore, writing passwords in notes or in unprotected files is prohibited. Multi-factor Authentication (MFA) must also be enabled whenever possible, especially for email and cloud platforms.

1.4 Compliance and Enforcement

Every user bears the direct responsibility for protecting their password while adhering to the stipulated complexity and periodic change instructions. The information technology officer will enforce the application of these rules technically through system settings [5]. Any deliberate violation of this policy, especially regarding the disclosure of the password to another person or tampering with related security controls/procedures, may lead to disciplinary action commensurate with the severity of the breach, which may result in the employee's termination.

2. Access Control Policy

2.1 Purpose and Scope

The Access Control Policy ensures giving employees exclusive access only to the files and resources they need to perform their specified tasks. The main idea relies on the vital principle known as the "Principle of Least Privilege" (PoLP). This procedure thus reduces the risks that an account breach could lead to the misuse or damage of information. This policy grants access to all systems, applications, and files that contain the Center's data for employees and contractors [1].

2.2 Core Principles

The access control process is based on three pillars: First, the principle of need-to-know as the basis for granting access authorization. The second is the Principle of Least Privilege, so that the employee is not granted any privileges that exceed their scope of work. Finally, the principle of periodic review of privileges is to ensure that the access levels granted to individuals match the current job role and also to prevent the accumulation of unused privileges that may weaken the center's security posture [5].

2.3 Detailed Policy Directives

These directives stipulate that any new access to the system must pass through a formal request from the direct manager and then be verified by the Information Technology department before implementation [6]. Conversely, access must be withdrawn on the same day in the event of an employee leaving or changing their job, with the closure of all digital accounts and the return of access keys. To enhance accountability, shared access accounts among several employees are not permitted, except for officially documented and tracked technical accounts. In addition, the information technology officer, in coordination with the administration, conducts a detailed review of all access lists at least once annually [6].

2.4 Compliance and Enforcement

The direct manager is responsible for ensuring that the level of access granted to the employee is limited to what is commensurate with their work needs. Compliance with policy practices is ensured through regular auditing of access logs to monitor unusual access patterns [5]. Any attempt to request, obtain, or use unauthorized access is considered a violation of this Access Control Policy and will be subject to immediate procedures, which may include disciplinary action, along with the possibility of legal responsibility.

3. Acceptable Use Policy

3.1 Purpose and Scope

The following policy describes behaviors that are acceptable and those that are prohibited when accessing computers, email, the internet network, or cloud storage services by any user using the technological assets of the Training Center. The policy shall be used to protect the Center's technological resources from possible harm and ensure that the resources are used in a legal, ethical, and professional manner [5]. This policy is applicable to all employees, contractors, and visitors who may use an asset of the Center.

3.2 Fundamental Principles

Three guiding principles form the basis for this policy: first, Work Purposes Use, by which "the first use of all Center resources shall be dedicated only to approved work purposes, allowing only incidental minimal personal use that does not interfere with work"; second, Protection Against Malware, whereby the user has a duty to take preventive measures in order not to install or distribute any malicious software, binding him to the use of approved protection tools; and third, Legal and Ethical Compliance, by which use that is inconsistent with applicable laws and regulations, or is abusive, threatening, or unprofessional, is prohibited.

3.3 Policy Directives

Examples of such prohibited activities include but are not limited to the use of the Center's assets for illegal activities, copyright infringement by downloading or publishing

copyrighted materials without a license, annoyance or harassment, and accessing forbidden content. Unless approved in writing by the IT Administrator for its security, any software-installation activity regarding work devices is not allowed. An employee should understand that no privacy is expected in all work resources, including email and internet use, and the Center reserves every right to monitor the network activities and traffic accordingly [5]. Also, employees are not allowed to consume any computational resources or bandwidth for purposes like cryptocurrency mining or downloading large non-work-related files.

3.4 Compliance and Enforcement

This policy shall form part of every employee's contract of employment in its entirety. The Center reserves the right to monitor at all times network use and data traffic to prevent intrusion attempts. Any infringement of this policy will attract severe disciplinary action, especially where there is any loss of security, and financial or reputational damage to the Center [1].

4. Device Security Policy

4.1 Purpose and Scope

The following policy describes the minimum required security standards for securing all end-user devices owned by the Center, such as laptops and desktops, or personally owned devices that are allowed to connect to the Center's network or access Center data, BYOD. It is designed to protect the Center's data from loss, theft, and unauthorized access to ensure business continuity and maintain the privacy of student and employee data [1].

4.2 Central Concepts

Device protection is based on three cornerstones: First, Mandatory Data Encryption [6], so that in the case of a device being lost or stolen, sensitive information cannot be read. Second, Continuous Physical Protection, which demands devices be always secured against theft or loss. Third, Secure Configuration and Control, to ensure that basic security settings are consistently applied, and that operating systems and applications are kept up to date.

4.3 Detailed Policy Directives

This sets several key mandates: Full Disk Encryption must be implemented on all laptops that contain "Confidential Data" owned by the Center [6]. All devices must have the appropriate Anti-Virus/Anti-Malware software installed, updated, and running in the background at all times. Similarly, all devices (desktop and laptop) must be set up so that, after 5 minutes of inactivity, the screen automatically locks and requires a password to unlock [6]. Removable media (such as USB drives) must be encrypted and only used when there is a business need to do so. Pertaining to Personal Devices (BYOD), highly sensitive data cannot be stored on them, and the employee must agree to possible Remote Wipe of work data by the IT Administrator should the device become lost or stolen [5]. Finally, the loss, theft, or misplacement of any device with data from the Center has to be reported immediately.

4.4 Compliance and Enforcement

The IT Administrator shall provide ongoing verification for the application of controls associated with encryption, virus protection status, and operating system updates on all Center devices. Any device identified as noncompliant with these minimum security standards will be automatically disconnected from the Center's network until the security gap is remediated [5]. Negligence in applying the required protection procedures—especially if leading to data loss by such negligence—may result in appropriate disciplinary action.

5. Data Protection and Privacy Policy

5.1 Purpose and Scope

The training center is entrusted with the sensitive personal data of its students, staff, and partners, a fundamental ethical and operational responsibility. This policy establishes a comprehensive and mandatory framework to ensure the most secure handling of this information, guaranteeing data confidentiality, integrity, and availability. The center is committed to full compliance with ethical standards, data protection principles, and relevant regulations, and to minimizing risks associated with data processing. Accountability is clearly defined for each individual, and this policy applies to all employees and contractors who handle the center's data.

This policy covers all digital and physical information assets owned or processed by the center. Data is classified into three levels based on its sensitivity: Confidential (High Sensitivity): This applies to the most critical information that absolutely requires a high level of protection. Examples include national identity numbers, credit card details, complete academic records, employee payroll information, and legal contracts. Internal (Medium Sensitivity): This refers to operational materials related to internal processes, such as minutes of internal meetings, draft training materials, meeting notes, and internal correspondence. Public data (low sensitivity): This consists of publicly available information, such as marketing brochures and lists of available courses. This classification guides all subsequent security controls [1].

5.2 Core Principles

The Training Center’s Data Protection and Privacy Policy is based on core principles that implement a comprehensive operational framework guiding how data is collected, processed, stored, retained, and destroyed. This framework aims to ensure that all activities are responsible, respect individual rights, and protect the interests of the institution. Through this commitment, the Center strives to build a trustworthy work environment that adheres to the highest ethical and regulatory standards, and to foster a comprehensive culture of awareness regarding the importance of information protection [1],[2].

The first principle is the commitment to being legal, fair, and transparent. This principle emphasizes that all data collection and processing activities must be supported by clear and justifiable legal grounds. Individual data may not be collected without a legitimate reason or without clearly informing individuals how and for what purpose it will be used.

The Center must handle data fairly, ensuring that it is not used in a way that could cause harm or negatively impact its owners. To achieve transparency, the Center must provide clear and understandable privacy notices that explain to students and staff: what data is collected, the purpose of its collection, who may share or disclose the data to, and the safeguards in place to protect it. This transparency is a cornerstone for building the necessary trust and ensuring the success of any educational institution [2].

The second principle is data minimization. This principle is based on the fundamental idea that personal data should only be collected when absolutely necessary. Any additional information represents an unjustified risk. Therefore, the center follows a strict policy that focuses solely on information directly related to essential work requirements, including registration, course management, payment processing, and mandatory communication. The institution also reviews data periodically to ensure that collected data is free of any unnecessary fields and to assess the need for any type of data before collection. This principle in the policy ensures that the database remains concise and as needed, thus reducing the likelihood of exposure to risks in the event of a security breach [2].

The third principle is accountability. This principle reinforces the idea that data protection is a comprehensive institutional responsibility shared by everyone. This role is not limited to the IT department, which oversees systems and establishes security controls. Therefore, it is essential that every employee is fully aware of their responsibilities and secure handling procedures and is qualified to identify and report risks. Senior management has a responsibility to lead and ensure compliance by providing the necessary training and resources and applying penalties when required. This principle helps to transform privacy protection into a core part of the center's professional culture [1].[2].

5.3 Detailed Policy Directives

The center must classify all data it processes according to its sensitivity in order to determine appropriate handling protocols and the necessary security controls. Data collection is subject to a strict minimization principle, whereby only what is absolutely necessary to achieve clearly defined purposes, such as registration, teaching, and payments, is collected. Furthermore, data retention beyond the specified usage period is not permitted.

The center is required to store confidential data digitally in approved and properly managed cloud environments that ensure the necessary encryption, strict access controls, and audit logs. Storing data outside of central systems—such as on local drives, personal cloud accounts, or unencrypted USB drives—is a clear violation of policy due to the lack of security and centralized governance. Physical documents must be stored in locked

cabinets when not in use, and employees must adhere to the clean office policy, which mandates that all sensitive materials be fully secured before leaving the workplace.

A strict access control system is in place, based on job-related permissions, whereby employees are only permitted to access information required for their work. Management formally reviews these permissions on a quarterly basis to ensure they remain consistent with job requirements. Sharing data with external third parties is not permitted except in cases of necessity, including with credit bureaus or payment platforms. Such sharing must be governed by binding contracts that include data protection clauses and require prior and guaranteed administrative authorization.

Data must only be kept for the duration mandated by legal or procedural necessity, and afterward, it must be securely destroyed according to a set destruction timetable. The destruction process includes the permanent deletion of digital data from systems and backups using secure methods that prevent future recovery, and the shredding of paper documents using cross-cutting machines to prevent any attempt at retrieval [1],[2].

5.4 Compliance and Enforcement

Each employee has a direct and personal responsibility to understand and consistently apply these guidelines as an integral part of their daily duties. This includes ensuring the correct classification of information based on its sensitivity level, using only secure and approved storage and transmission methods, and immediately reporting any data mishandling, loss, or unauthorized access to their supervisor or IT contact.

Management has ultimate responsibility for ensuring policy implementation by providing the necessary resources, conducting regular compliance assessments, and fostering a culture of data stewardship. Violations will be met with disciplinary measures commensurate with the severity of the breach and may result in termination of employment. It is important to note that serious violations may subject both the individual and the organization to legal accountability and fines. This policy is renewed and reviewed annually to maintain its relevance and effectiveness in light of organizational and operational developments.

6. Incident Response Policy

6.1 Purpose and Scope

This policy aims to establish a clear and structured methodology for addressing any cybersecurity emergency affecting our training center. In a small organization without a dedicated security team, having a detailed and comprehensive response plan for all staff is the first line of defense and essential for ensuring business continuity. The ultimate goal is to minimize disruption (whether operational downtime or financial losses), ensure the confidentiality and integrity of student and staff data, protect the center's reputation, and guarantee full compliance with all legal requirements regarding incident and data breach reporting [2],[3]. The policy covers all aspects of the business, including digital systems, physical equipment, and every employee within the organization. A security incident is defined as any situation, whether real or suspected, that poses a risk or causes harm to the confidentiality, integrity, accuracy, or availability of our information, or that disrupts the normal operations of the center. Examples of such common incidents include: infection with malware such as ransomware, a successful phishing attempt to steal login credentials, loss/theft of any device containing business information, unauthorized access to student records or systems, our online services being subjected to attacks such as denial-of-service attacks, or employees abusing their privileges.

6.2 Core Principles

Our cyber incident response policy is based on five key principles designed to guide our actions during crises and best protect our educational mission.

Preparation Prevents Confusion: We understand that the best defense is proactive planning, not a reactive response. This means dedicating time to regular training on response procedures and carefully defining each person's role with complete clarity. When an incident occurs, we move calmly and confidently according to a pre-established plan [3],[7].

Protecting the Continuity of the Educational Process: Our primary and fundamental role is to ensure the continuity of our students' learning at the center. Therefore, the ultimate goal of all containment and recovery measures is to minimize any impact on training platforms and student records. Every decision we make must prioritize the continuity of our educational mission, as our training data and services are among our most valuable assets [3].

Unified Leadership and Clear Communication: Crises require a leader to control the situation, provide information, and guide the response team in making critical decisions.

Communication with staff, students, and external parties must be coordinated, clear, and timely to maintain the center's reputation and trust and prevent the spread of rumors [7].

Acting on facts and learning from mistakes: No action is taken until thorough verification and evidence are gathered. It enables a correct assessment of the threat so that the most effective response can be chosen. Most importantly, every incident is viewed as an opportunity for learning and development, transforming it into future improvements [3].[7].

Ethical and legal commitment: This principle requires that all our actions be based on adherence to the highest ethical and legal standards. We must protect the privacy of our students' and staff's data, fully comply with data breach reporting laws, and ensure transparency in notifying affected parties and legal authorities in a timely manner [2].

6.3 Detailed Policy Directives

The success of this policy hinges on the commitment to immediate and mandatory reporting by every employee at the center. Employees form a "human detection network," based on the principle that any employee who senses or suspects any unusual activity, such as strange device behavior, a missing device, suspicious emails, or an unexplained system outage, must immediately disclose and report it to their direct supervisor or a technical support contact. This ensures that the incident is addressed directly by both parties simultaneously without delay. The reporter is required to share every relevant detail they can about the incident. The reporter's role is limited to secure isolation and reporting only. They may disconnect the affected device from the network if the issue is minor, but they are not permitted to take any action that could destroy evidence or hinder the official response to the incident.

Upon receiving a report, the Emergency Response Team (IRT) is activated. The team implements a sequential and systematic approach, beginning with a containment phase focused on immediate isolation (such as closing compromised accounts, isolating any infected servers, and fragmenting the network). This is followed by a post-incident stabilization phase (such as applying updates and changing passwords) to prevent the attacker from returning. Next, the investigation and assessment phase begins to determine the source of the attack, identify the affected area (including systems and data that were accessed, modified, or stolen), and assess the legal and business implications. Following the determination of the scope, the eradication step focuses on removing the root cause of the threat. This is followed by the recovery phase, where systems and data are carefully restored from reliable backups and verified to be fully functional. Finally, after the

incident is resolved and operations have returned to normal, a final and essential review is conducted. This review documents the detailed sequence of events, assesses the effectiveness of our response, calculates the total cost, and, most importantly, identifies lessons learned to prevent a recurrence of the problem [3].[7].

6.4 Compliance and Enforcement

All employees must complete basic and annual refresher training to learn how to identify incident signs and understand the correct reporting procedures. This training focuses on practical scenarios related to employees' daily tasks. We emphasize that hesitation, delay, or failure to report any suspected incident is a serious policy violation, and such negligence causes further harm to the center.

To ensure the effectiveness of the response plan, it is tested and refined annually through simulation exercises conducted during meetings where realistic incident scenarios are discussed to identify and correct any procedural deficiencies. In the event of an actual incident, the center manager is responsible for administrative, financial, and public communication leadership, while the technical support officer assumes the technical authority to contain and eliminate the threat. All records and documentation related to incidents and exercises must be retained as part of the center's security records. Any violation of this policy, such as failure to report or obstruction of the response process, will result in disciplinary action commensurate with the severity of the offense.

7. Email and Communication Policy

7.1 Purpose and Scope

Rules are defined in this policy for how utilize the official electronic communications channels of the training center, specifically email messages. Since email is the primary tool for communication and interaction at our center, it also presents a significant vulnerability to threats such as phishing and data breaches. Our aim with this policy is to protect the center from these risks and maintain our professional reputation. These guidelines apply to all employees, staff, contractors, and anyone using the center's official communication accounts [1],[8].

7.2 Core Principles

Our communication practices are based on three guiding principles to ensure security and professionalism:

Be vigilant and always verify: All employees must treat emails with extreme caution and avoid rushing to open any link or attachment before verifying the sender's identity and the content's integrity [8],[9].

Data protection starts with the method of transmission: Confidential information should never be sent through insecure methods. It is essential that data security is embedded into all of our daily communication [8].

Professional representation of the center: Every message sent reflects the image of the educational center. All correspondence must be clear, respectful, and always in accordance with the institution's professional standards [1].

7.3 Detailed Policy Directives

Personal responsibility in handling email is unavoidable, and every employee is expected to exercise critical judgment when dealing with messages. Caution should be exercised when dealing with suspicious addresses, messages that raise suspicion, have an unwarranted tone of urgency, or unexpectedly request sensitive information. To secure the center's data, we emphasize that sending any highly sensitive or internal information (such as student grades or payment details) via email, whether as direct text or as a plain, unencrypted, or unprotected attachment, is strictly prohibited. The standard procedure for transferring such data is to upload the file to the center's secure and official cloud storage platform and then share the access link with the relevant party, clearly defining viewing and editing permissions. Regarding usage, official emails should be reserved solely for essential work purposes, and the use of an official, approved signature and a high level of professionalism must be maintained. Finally, to ensure the protection of internal data, the automatic forwarding of company emails to any personal email address without prior written and official authorization from the IT department is strictly prohibited.

7.4 Compliance and Enforcement

Compliance with this policy is mandatory for everyone. This commitment is supported by ongoing cybersecurity awareness training, including phishing test training. The IT administrator can implement technical controls (e.g., attachment blocking or spam filtering) to enforce these rules, while management is responsible for ensuring its teams adhere to this policy. Any violation of these rules, especially if it results in data breaches or a security incident, will result in disciplinary action commensurate with the severity of the violation.

8. Physical Security Policy

8.1 Purpose and Scope

The policy aims to establish the necessary foundations to ensure the safety of the training center's physical assets and facilities, and to protect the confidential data stored therein from any breach, theft, or damage caused by external factors. Physical security is a cornerstone of digital security; a stolen device or unauthorized access to data room can render even the strongest electronic security measures ineffective. This policy applies to every individual working at the organization, whether permanent or contracted, as well as visitors, and its controls encompass all our administrative sites, workspaces ,data storage locations, and any company-owned equipment used inside or outside the center [1].

8.2 Core Principles

Our physical security policy is supported by three fundamental pillars. The first pillar is a multi-layered protection approach, which means implementing interconnected security measures as multiple, integrated barriers– such as building access control system, rules for work areas, and a sense of individual responsibility –to ensure that the organization is not compromised by crossing any single boundary. The second pillar is the restrict access as needed principle, which mandates that physical access to sensitive areas and resources be restricted exclusively to employees whose work requires it. The third pillar is a collective commitment to security and shared responsibility, which emphasizes that maintaining a secure physical environment is the responsibility of every member of the organization [1],[8].

8.3 Detailed Policy Directives

The center maintains a strict access control system. Office doors must remain locked after official working hours. Every visitor must register at the reception desk and must be

accompanied by an authorized escort. A clean office and clear screen policy is mandatory for all employees. Upon leaving work or for a specified period, any confidential documents must be stored in secure drawers or cabinets. It is required that all personal devices (e.g., tablets and laptops) must be placed in storage and properly protected. All desktop computers must be set to automatically lock after ten minutes of inactivity, and employees are responsible for locking their screens themselves when leaving the office. Regarding mobile devices used outside the center, it is strictly forbidden to leave any mobile device storing company information unattended in public areas [1],[8].

8.4 Compliance and Enforcement

It is mandatory for every employee to read and follow these instructions. Management will conduct surprise audits at set intervals to ensure compliance with the "Clean Desk and Clear Screen" policy. The loss or theft of any company equipment or portable storage devices, such as USB drives containing company data, must be reported as a security incident requiring immediate notification of the supervisor and the technical support department. Violation of this policy, or any negligence that results in a security breach, will subject the perpetrator to disciplinary measures commensurate with the severity of the violation. These measures may range from written warnings and mandatory training to termination of employment in cases of repeated violations.

9. Training and Awareness Policy

9.1 Purpose and Scope

This policy establishes a mandatory, ongoing training program to raise cybersecurity awareness among all members of the training center. Given the absence of a dedicated security team, our employees are considered the first and most crucial line of defense. The goal of this policy is to create a robust human firewall by ensuring that every employee is vigilant and proactive in protecting the organization. This policy is relevant to every employee, regardless of their role or technical background [4].

9.2 Core Principles

Our training methodology is based on three core principles. The first principle is **sustainability in awareness**, which states that security is an ongoing practice deeply rooted in the organization's culture, not merely a passing course, and must be continuously updated to address evolving threats. The second principle is **practical application**, ensuring that all training materials are directly linked to employees' daily

tasks and the security risks and threats the organization faces, with the aim of translating theoretical knowledge into actionable behavior. The third principle is **shared responsibility**, which emphasizes that while management is committed to providing tools and establishing policies, each individual is personally responsible for applying their learning to protect the organization's information, systems, and reputation [4].

9.3 Detailed Policy Directives

The training center will adopt a systematic pilot plan for all employees. This plan begins with a mandatory security orientation program for new staff, which must be completed before they are granted access to the systems. Furthermore, yearly update sessions will be conducted for all personnel to maintain awareness regarding new policies and evolving threats. To enhance practical application, the organization conducts periodic phishing simulations, sending employees fake emails and providing them with helpful guidance through their responses, without any penalties. Beyond formal meetings, ongoing awareness campaigns will be implemented, including sending monthly security tips, posting notices in public areas, and holding brief security discussions during team meetings [4].

9.4 Compliance and Enforcement

Completing assigned training programs is an integral part of employment requirements for all employees. It is the responsibility of managers to ensure full participation, attendance, and completion of all training sessions. Failure to complete required training may result in the temporary suspension of system privileges until the training is fully completed. Additionally, phishing campaigns can be used for educational purposes. Employees fall victim to phishing emails, learning how to avoid them in the future. The information gathered from the assessments utilized to measure the efficiency of staff training programs, and determine where they need upgrading.

Ignoring the security training rules learned constitutes a clear policy violation and may result in disciplinary action.

Justification & Importance

The cybersecurity policies presented here are not just a set of formal rules; they form a carefully designed framework that directly addresses the real risks faced by small organizations relying heavily on digital systems for essential tasks such as student registration, communication, payment processing, and data storage. Research indicates that small enterprises are particularly vulnerable to cyber threats, and adopting structured security practices significantly enhances resilience against attacks [10], [11].

The Password Policy sets the first line of defense by enforcing strong authentication practices. Studies have shown that weak or poorly implemented password rules often lead to security breaches, whereas enforcing complexity and length reduces the likelihood of unauthorized access to sensitive systems and data [12].

The Access Control Policy applies the principle of least privilege, which is fundamental to modern access management. Role-Based Access Control (RBAC) effectively limits unnecessary permissions and safeguards sensitive information by assigning access rights according to organizational roles rather than individual users [13].

The Acceptable Use Policy clarifies which actions are prohibited, such as installing unauthorized software or accessing malicious content. Empirical evidence highlights that clear policy guidance, combined with employee compliance, significantly reduces malware exposure and improves overall cybersecurity hygiene [11].

The Device Security Policy targets endpoint vulnerabilities, including laptops and portable devices that are frequently exploited in attacks. Studies of SMEs emphasize that unmanaged or insecure endpoints are high-risk points, and enforcing encryption, updates, and secure configurations strengthens defenses against data breaches and device compromise [11].

In organizations without dedicated cybersecurity teams, the **Incident Response Policy** provides a predefined plan to detect, respond to, and recover from security incidents. Literature on incident response shows that organizations with documented plans are better prepared, suffer less operational disruption, and can more effectively mitigate financial losses [14].

The **Email and Communication Policy**, reflecting regulatory guidance on protection from social engineering [15], limits the transmission of sensitive information through insecure channels and promotes phishing awareness. In small organizations, where email is central to managing student data and schedules, this policy directly reduces the risk of credential theft and data leakage.

Finally, emphasizing human-centric security controls [15], the **Training and Awareness Policy** ensures that continuous education turns employees from potential vulnerabilities into an active line of defense. Without such training, risks like phishing attacks or accidental data exposure could escalate rapidly, with serious operational, financial, and reputational consequences.

Taken together, these policies create an integrated cybersecurity framework. Neglecting them exposes small training centers to compounded risks: a single phishing email could compromise credentials, weak access controls could allow unauthorized data access, and the absence of incident response plans could prolong disruptions. Moreover, without employee awareness, similar incidents are likely to recur, amplifying operational, financial, and reputational damage. These examples demonstrate why the policies must be implemented collectively rather than as isolated measures.

Compliance & Enforcement

Compliance with all cybersecurity policies is mandatory for every employee, contractor, and affiliated personnel. Each individual is responsible for correctly handling sensitive data, adhering to secure practices, and promptly reporting any irregularities or security breaches. Research highlights that employee awareness and accountability play a critical role in strengthening cybersecurity resilience, particularly within small organizations where human error remains a common attack vector [16].

Management holds primary responsibility for ensuring the effective implementation of these policies by allocating appropriate resources, conducting regular compliance assessments, and fostering a culture of cybersecurity accountability. Policy violations are addressed seriously and may result in disciplinary actions proportionate to the severity of the breach, including formal warnings, mandatory retraining, suspension of system access, or termination. Repeated or severe violations may also expose both individuals and the organization to legal and regulatory consequences, emphasizing the importance of strict adherence [17][15].

Periodic reviews and updates of cybersecurity policies are essential to ensure their continued relevance in an evolving threat landscape. This overarching compliance framework underpins all subsequent policies—including Password Policy, Access Control, Device Security, Email and Communication, Incident Response, and Training and Awareness—ensuring consistent enforcement and integration, and supporting a robust, human-centered cybersecurity environment [17].

Conclusion

A detailed cybersecurity policy framework designed for a small training center setting was provided in this study. Password management, access control, appropriate usage, device security, data protection and privacy, incident response, email and communication security, physical security, training, and awareness were among the key security categories covered. To ensure uniformity and clarity throughout the company, each policy was designed to precisely outline its goals, guiding principles, operational instructions, and compliance criteria.

This framework highlights that security is a shared responsibility between management and employees by addressing both the technological and human components of cybersecurity. Incorporating compliance and enforcement procedures guarantees that policies are actively applied, reviewed, and changed in response to changing threats, rather than just being published. Assigning precise roles, duties, and repercussions also promotes effective risk management and increases accountability.

Overall, this cybersecurity policy framework gives the training center a solid and scalable platform for safeguarding sensitive data, mitigating security risks, and increasing organizational resilience. Implementing these rules will help to develop a security-conscious culture, assure regulatory compliance, and support the organization's long-term operational stability in an increasingly digital and vulnerable world.

References

[1]International Organization for Standardization, *ISO/IEC 27001 :2022, Information security, cybersecurity and privacy protection: Information security management systems, Requirements*, Geneva, Switzerland, 2022.

[2] European Parliament and Council of the European Union, *Regulation (EU) 2016/679 of 27 April 2016 (General Data Protection Regulation),* Official Journal of the European Union, 2016.

[3] National Institute of Standards and Technology, *Computer Security Incident Handling Guide*, NIST Special Publication 800-61 Revision 2, Gaithersburg, MD, USA, 2012.

[4] National Institute of Standards and Technology, *Building an Information Technology Security Awareness and Training Program*, NIST Special Publication 800-50, Gaithersburg, MD, USA, 2003.

[5] M. E. Whitman and H. J. Mattord, *Management of Information Security*, 6th ed. Boston, MA: Cengage Learning, 2018.

[6] R. Ross, M. McEvilley, J. M. Scholl, and K. L. Scholl, "Security and Privacy Controls for Information Systems and Organizations," *NIST Spec. Publ. 800-53 Rev. 5*, Sep. 2020. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-53r5

[7] International Organization for Standardization and International Electrotechnical Commission, *ISO/IEC 27035-1:2016, Information technology — Security techniques — Information security incident management — Part 1: Principles of incident management*, Geneva, Switzerland, 2016.

[8] International Organization for Standardization, *ISO/IEC 27002:2022 — Information security, cybersecurity and privacy protection — Information security controls*, Geneva, Switzerland, 2022.

[9] National Institute of Standards and Technology, Trustworthy Email, NIST Special Publication 800-177, Gaithersburg, MD, USA, 2019.

[10] F. Alharbi et al., “The impact of cybersecurity practices on cyberattack damage: The perspective of small enterprises in Saudi Arabia,” Sensors, vol. 21, no. 20, p. 6901, 2021. [Online]. Available: https://doi.org/10.3390/s21206901

[11] M. El-Hajj and Z. A. Mirza, “Protecting small and medium enterprises: A specialized cybersecurity risk assessment framework and tool,” Electronics, vol. 13, no. 19, p. 3910, 2024. [Online]. Available: https://doi.org/10.3390/electronics13193910

[12] E. Y. Güven, A. Boyaci, and M. A. Aydin, “A novel password policy focusing on altering user password selection habits: A statistical analysis on breached data,” Computers & Security, vol. 113, p. 102560, 2021. [Online]. Available: https://doi.org/10.1016/j.cose.2021.102560

[13] “What is role-based access control (RBAC)?,” IBM, 2024. [Online]. Available: https://www.ibm.com/think/topics/rbac

[14] A. Aldabjan, S. Furnell, X. Carpent, and M. Papadaki, “Cybersecurity incident response readiness in organisations,” in Proc. 10th Int. Conf. Inf. Syst. Secur. Privacy - ICISSP, 2024, pp. 262–269. [Online]. Available: https://doi.org/10.5220/0012487600003648

[15] SAMA. (2024). Cybersecurity Governance Framework. Saudi Arabian Monetary Authority. [Online]. Available: https://rulebook.sama.gov.sa/en/311-cyber-security-governance-0

[16] Benjamin et al., 2024. Cybersecurity awareness and human factors in small organizations. [Online]. Available: https://doi.org/10.30574/gjeta.2024.19.2.0084

[17] Elsevier, Computers & Security. (2023). The Role of Management in Implementing Cybersecurity Policies. [Online]. Available: https://doi.org/10.48009/2_iis_2023_105